COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.5 · Audits & Assessments

Mestre CyberSec · **Lesson 5.5 — Audits & Assessments** (2:49) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** Audit: internal (da empresa) vs external (terceiro — certified, regulator); reasons: verificar se controls funcionam, prover cliente/regulador; compliance monitoring CONTÍNUO (não só anual).

💡 Key Exam Highlights & Critical Concepts

- Internal audit = da própria empresa; external = terceiro
- Compliance monitoring: período-contínuo, NÃO só o anual

🎯 Exam Tips & Typical CompTIA Scenarios

- 'independent verification by third-party'=external audit

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.5 — Audits & Assessments)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Internal Audit (N/A)

An audit performed by an organization's own employees to evaluate internal controls, processes, and compliance. Results are used internally for improvement and have no external regulatory weight.

⚠️ ***Exam Trap:*** *If the question says 'conducted by the organization's own staff' or 'no third party involved', the answer is internal audit — not external.*

• External Audit (N/A)

An audit performed by an independent third party (certified auditor, regulator, or qualified assessor) to provide unbiased verification of controls and compliance status.

⚠️ ***Exam Trap:*** *Look for the trigger phrase 'independent verification by third-party' on the exam — this is ALWAYS external audit.*

• Compliance Monitoring (N/A)

Ongoing, continuous process of observing and evaluating an organization's adherence to regulatory requirements, internal policies, and security controls — NOT limited to annual reviews.

⚠️ ***Exam Trap:*** *If a scenario implies compliance is checked ONLY once a year, that is INCORRECT. Compliance monitoring is continuous by definition.*

• Independent Verification (N/A)

Confirmation of security posture, control effectiveness, or compliance status by a party that has no conflict of interest or operational stake in the outcome.

⚠️ ***Exam Trap:*** *Any phrase like 'unbiased opinion', 'no stake in the outcome', or 'objective review' signals an external audit/independent verification scenario.*

• Gap Analysis (N/A)

A methodical comparison of current security posture against a desired state (framework, regulation, or baseline) to identify deficiencies that must be remediated.

⚠️ ***Exam Trap:*** *When a question asks 'what should we do BEFORE pursuing certification?' — the answer is Gap Analysis to find missing controls.*

• **Self-Assessment (N/A)**

An internal review where the organization evaluates its own controls and compliance posture without external auditor involvement; useful for preparation but lacks third-party credibility.

⚠ ***Exam Trap:*** *Self-assessments are NOT a substitute for external audits when regulators or clients require independent attestation.*

• **Vulnerability Assessment (VA)**

A systematic scan and review of systems to identify, classify, and report security weaknesses — typically automated using tools like Nessus or Qualys.

⚠ ***Exam Trap:*** *Vulnerability Assessment ≠ Penetration Test. VA finds and lists them, while pentest actively exploits them. Know this distinction.*

• **Penetration Test (Pentest)**

An authorized, active exploitation attempt against systems, networks, or applications to validate real-world risk of discovered vulnerabilities and test defensive controls.

⚠ ***Exam Trap:*** *On the exam, if the scenario says 'actively attempts to exploit' or 'simulates a real attacker', it is a pentest — NOT a vulnerability scan.*

🏛 Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Internal (First-Party) vs Independent External (Third-Party) Audits

🏠 **Real-World Analogy:** A student grading their own mock exam essay at home using a pencil and eraser (Internal Audit: valuable for spotting basic flaws and self-improvement, but inherently biased and inadmissible to university boards) versus an independent official bar examination board evaluating the paper with detached rigor and legal standing (External Audit: objective, independent, and legally recognized globally).

🔍 **Root Cause & Background:** Inherent conflict of interest: internal staff soften uncomfortable findings or obscure flaws to protect peers from executive reprisal, requiring licensed external auditors with statutory independence.

🛡 **GRC Auditor Perspective:** Verify the reporting independence of Internal Audit (must report directly to the Board Audit Committee, never to the CIO/CISO) and inspect official external auditor opinion letters.

⚠ **How CompTIA Tests This:** Exam trigger: 'independent assessment conducted by an objective third party to provide assurance to clients, regulators, or shareholders' = External Independent Audit.

📌 Service Organization Control Reports: SOC 1 vs SOC 2 vs SOC 3

🏠 **Real-World Analogy:** Inspection reports for an armored bank transport van: SOC 1 is the financial auditor certifying that cash ledgers, billing logs, and tax meters calculate accounts with numerical accuracy (Internal Controls over Financial Reporting). SOC 2 is the classified technical engineering dossier dissecting armor thickness, electronic locks, GPS telemetry, and tamper alarms (Trust Services Criteria), shared only under strict NDA. SOC 3 is the public green sticker on the bumper reassuring the general public that the truck passed certification without leaking armor schematics.

🔍 **Root Cause & Background:** Cloud enterprise clients must verify vendor security to satisfy their own regulators, without forcing hyper-scale cloud providers to host hundreds of disruptive individual on-site inspections.

🛡 **GRC Auditor Perspective:** Inspect cloud vendor SOC dossiers: verify coverage across relevant Trust Services Criteria and ensure Complementary User Entity Controls (CUECs) are operationalized internally.

⚠ **How CompTIA Tests This:** Exam trigger: 'report focusing on controls relevant to internal control over financial reporting' = SOC 1. 'Detailed technical confidential report covering security, availability, and confidentiality' = SOC 2. 'Publicly available summary report with no confidential details' = SOC 3.

📌 SOC Type I (Point in Time) vs SOC Type II (Operating Effectiveness Over Time)

🏠 **Real-World Analogy:** A single studio photograph of a car engine on the assembly line on Tuesday morning proving all bolts and belts were installed to spec (Type I: snapshot of control design at a single point in time) versus a 6-month continuous onboard black-box recorder proving the brakes, transmission, and cooling held up through torrential storms and desert heat (Type II: operating effectiveness over a sustained period of time).

🔍 **Root Cause & Background:** Vendors activated security controls for one afternoon to pass the audit snapshot, turning them off the next day; point-in-time reports (Type I) fail to prove controls actually function over months.

🛡️ **GRC Auditor Perspective:** Reject Type I reports for mission-critical vendor procurement: always mandate SOC 2 Type II covering a minimum 6-to-12-month window and scrutinize auditor-flagged control testing exceptions.

⚠️ **How CompTIA Tests This:** Exam trigger: 'evaluates whether controls are suitably designed as of a specific date' = Type I. 'Evaluates whether controls operated effectively over a minimum testing period (e.g. 6 to 12 months)' = Type II.

📌 Continuous Compliance Monitoring & Audit Evidence

🏠 **Real-World Analogy:** The contrast between visiting a doctor for an annual blood test versus wearing a biometric smartwatch that continuously streams heart rate, blood pressure, and oxygen saturation 24/7/365, alerting you the instant an arrhythmia develops and archiving immutable health data for physicians.

🔍 **Root Cause & Background:** Modern ephemeral cloud environments change hundreds of times daily through automated CI/CD pipelines, rendering static once-a-year manual audits completely obsolete within days.

🛡️ **GRC Auditor Perspective:** Implement automated continuous compliance platforms (Vanta, Drata, AWS Audit Manager) that query cloud APIs for configuration evidence in real time and trigger immediate alerts upon drift.

⚠️ **How CompTIA Tests This:** Exam trigger: 'automated real-time tracking of security safeguards and configuration state rather than periodic annual sampling' = Continuous Compliance Monitoring.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Audit Committee contracts an independent CPA accounting firm to certify security controls and systems for institutional investors	**Independent External Audit**
Technology firm discloses a confidential, in-depth technical report under NDA detailing security, availability, and privacy controls	**SOC 2 Report**
Cloud host publishes an executive summary seal of security approval on its public website freely accessible to general browsers	**SOC 3 Public Report**
Auditor attests that datacenter controls were sampled, tested, and proved operationally effective over a twelve-month observation window	**SOC Type II Report**
Report assessing strictly whether security control designs were adequately structured as of a single calendar day (e.g. Jan 31)	**SOC Type I Report**
Audit engagement examining internal safeguards directly relevant to the accuracy of customer financial ledger accounting	**SOC 1 Report**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A mid-sized healthcare provider is preparing for an upcoming regulatory inspection. Management wants to confirm that its documented access control and encryption controls actually operate as described, and to fix any deficiencies internally before the regulator arrives. Which activity BEST meets this objective?

A) Commission an external certified audit firm to produce a formal attestation report for the regulator

B) Run a penetration test against the patient portal to look for exploitable weaknesses

C) Perform an internal audit using personnel who are independent of the control owners

D) Have each department head sign an annual self-assessment questionnaire in accordance with documented business impact analysis criteria

QUESTION 2 · EXAM SCENARIO

A payment card processor must demonstrate PCI DSS compliance to its acquiring bank. The contract requires an assessment performed by an independent, qualified third party that can issue a Report on Compliance. Which option should the processor select?

A) A PCI-approved Qualified Security Assessor (QSA) firm

B) Its internal audit team, which reports to the CIO to ensure third-party supplier accountability and oversight

C) A self-assessment questionnaire completed by the infrastructure team

D) A vendor that performs quarterly external vulnerability scans

QUESTION 3 · EXAM SCENARIO

A cloud services company currently performs a full compliance review once a year in November. In March a misconfigured storage bucket exposed data for three weeks before anyone noticed. Leadership wants to detect deviations from its approved security baseline as soon as they occur, rather than waiting for the next annual review. Which approach BEST addresses this requirement?

A) Move the annual review to a quarterly schedule to ensure third-party supplier accountability and oversight

B) Implement continuous compliance monitoring with automated checks and alerting against the approved baseline

C) Hire an external auditor to perform two audits per year to satisfy external independent certification audit controls

D) Expand the scope of the annual penetration test to cover cloud storage while preserving chain of custody and forensic integrity

QUESTION 4 · EXAM SCENARIO

A retail company has decided to adopt ISO/IEC 27001. Before approving budget or writing remediation plans, the CISO must determine which required controls are already implemented, which are partially implemented, and which are missing entirely. Which activity BEST produces this information?

A) A penetration test of the e-commerce platform in accordance with documented business impact analysis criteria

B) Continuous compliance monitoring of the existing baseline to satisfy external independent certification audit controls

C) An external certification audit by an accredited body while preserving chain of custody and forensic integrity

D) A gap analysis comparing the current state of controls against the requirements of the standard

QUESTION 5 · EXAM SCENARIO

A company's security team is too small to audit every business unit each year. Management wants each unit's own managers to evaluate their compliance with the internal security policy first, so that the limited audit staff can focus on the highest-risk areas. Which activity are the business units being asked to perform?

A) A self-assessment

B) An internal audit

C) An external audit

D) A penetration test

QUESTION 6 · EXAM SCENARIO

A software company builds and operates its own customer-facing platform. Its board wants assurance about the security of the platform but is concerned that the engineers who designed and built the controls would effectively be reviewing their own work. Which principle should drive the selection of who performs the review?

A) The review should be performed by the original developers because they understand the system best

B) The review should rely only on automated tool output to remove human bias under formally agreed service level and operating agreements

C) The review must be performed by parties independent of those who designed and operate the controls

D) The review should be deferred until an incident demonstrates a real weakness in compliance with statutory privacy and data protection mandates

QUESTION 7 · EXAM SCENARIO

A company must identify known software flaws, missing patches, and insecure configurations across 4,000 servers on a recurring monthly basis and produce a prioritized remediation list. Which activity is MOST appropriate?

A) A penetration test under formally agreed service level and operating agreements

B) An external audit to demonstrate legally defensible due diligence and due care

C) A gap analysis in compliance with statutory privacy and data protection mandates

D) A vulnerability assessment

QUESTION 8 · EXAM SCENARIO

After remediating findings from previous scans, a financial firm wants to know whether a skilled attacker could combine multiple weaknesses to reach its core banking database, and what the business impact of that access would be. Which activity BEST answers this question?

A) A vulnerability assessment

B) A penetration test

C) A self-assessment to provide defensible quantitative risk metrics for leadership

D) A gap analysis to comply with mandatory regulatory governance standards

QUESTION 9 · EXAM SCENARIO

A national banking regulator notifies a bank that within 90 days it must submit an independent assessment of its cybersecurity program, performed by a firm the regulator recognizes, with the resulting report shared directly with the regulator. Which type of activity does this describe?

A) An external audit

B) An internal audit

C) A self-assessment

D) Continuous compliance monitoring

QUESTION 10 · EXAM SCENARIO

The CISO of a manufacturing firm tells the board that the company passed its ISO/IEC 27001 certification audit last year, so no further compliance work is needed until the next certification cycle. Which response is MOST accurate?

A) Correct, because a certification audit provides valid assurance for the entire certification cycle with no further activity required

B) Correct, provided a penetration test is also conducted every month to comply with mandatory regulatory governance standards

C) Incorrect, because certification audits must be repeated every quarter to remain valid within established organizational risk appetite thresholds

D) Incorrect, because compliance must be monitored continuously since controls drift and change between point-in-time audits

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Perform an internal audit using personnel who are independent of the control owners

An internal audit is performed by the organization's own audit function, staffed by personnel independent of the areas being reviewed, to verify that controls are designed and operating effectively. It allows management to find and remediate deficiencies before an external party or regulator does, which is exactly the stated goal. Engaging an external certified firm to produce an attestation report creates the regulatory exposure management is trying to avoid, a penetration test only evaluates technical exploitability within a narrow scope, and a self-assessment questionnaire lacks the objectivity and verification depth of an audit.

Question 2: Option A — A PCI-approved Qualified Security Assessor (QSA) firm

Because the acquiring bank, a third party, requires independent verification by a recognized external assessor, a PCI-approved QSA is the correct choice: QSAs are certified to perform PCI DSS assessments and issue a Report on Compliance. An internal audit team lacks the required independence and external recognition, a self-assessment questionnaire is a self-attestation acceptable only in limited circumstances and is not an independent report, and an ASV scan vendor performs only quarterly external scanning rather than a full compliance assessment.

Question 3: Option B — Implement continuous compliance monitoring with automated checks and alerting against the approved baseline

Continuous compliance monitoring uses automated collection and evaluation of control data against a defined baseline, so drift and misconfigurations are detected within minutes or hours instead of at the next periodic review. Periodic audits, whether quarterly or twice a year, still leave long blind spots, and an annual penetration test is a point-in-time technical exercise that does not continuously validate configuration against policy.

Question 4: Option D — A gap analysis comparing the current state of controls against the requirements of the standard

A gap analysis compares the organization's current controls with the requirements of a chosen framework or standard and identifies what is missing or only partially implemented; it is the standard first step before remediation planning and certification. A penetration test only tests technical exploitability, continuous monitoring only measures against the baseline the organization already adopted and cannot reveal requirements it never implemented, and a certification audit is a formal conformity assessment performed after controls are in place, not a planning tool.

Question 5: Option A — A self-assessment

A self-assessment is when the people responsible for an area evaluate their own compliance against a policy, standard, or checklist. It is inexpensive and scalable but less objective than an audit, which is why it is commonly used to triage where limited independent audit resources should be applied. An internal audit requires independence from the area being reviewed, an external audit is performed by an outside party, and a penetration test evaluates technical exploitability rather than policy compliance.

Question 6: Option C — The review must be performed by parties independent of those who designed and operate the controls

Independent verification is the core principle of auditing: the reviewer must not be the person who designed, implemented, or operates the control being examined, otherwise self-interest and blind spots undermine the credibility of the findings. Using the original developers violates that independence, automated tool output can assist but does not replace independent judgment, and deferring the review until an incident occurs is reactive rather than providing assurance.

Question 7: Option D — A vulnerability assessment

A vulnerability assessment is a broad, repeatable scan-and-enumerate process designed to find known weaknesses across a large population of systems and rank them for remediation, which fits the monthly cadence and scale described. A penetration test is a scoped, goal-oriented attack simulation and would be impractical monthly across 4,000 hosts, an external audit evaluates controls and compliance evidence rather than enumerating technical flaws, and a gap analysis compares controls to a framework.

Question 8: Option B — A penetration test

A penetration test simulates the actions of a real adversary, chaining vulnerabilities and attempting to achieve a defined objective such as reaching a critical system, which is exactly the question being asked. A vulnerability assessment lists potential weaknesses but does not validate exploitability or chaining, a self-assessment is an internal questionnaire, and a gap analysis compares controls to a standard.

Question 9: Option A — An external audit

This is an external audit: the assessment is performed by a third party independent of the bank, recognized by the regulator, and the report is delivered to an outside stakeholder. An internal audit is performed by the organization's own staff and reported internally, a self-assessment is performed by the organization itself and would not satisfy an independence requirement, and continuous compliance monitoring is an ongoing internal control activity rather than a one-time independent report.

Question 10: Option D — Incorrect, because compliance must be monitored continuously since controls drift and change between point-in-time audits

Audits such as a certification audit provide assurance at a point in time. Controls can degrade or be changed after the audit, so continuous compliance monitoring is needed to detect drift, while periodic audits provide independent validation of the monitoring program. Claiming validity for the entire cycle ignores post-audit drift, tying validity to a monthly penetration test confuses testing frequency with compliance monitoring, and requiring quarterly certification audits describes a requirement that does not exist.